

Security and Data Protection Policy

Policy owner: Chief Information Security Officer · Version 3.0 · Reviewed March 2026

1. Scope

This policy applies to all Orbitra employees, contractors and systems that store or process customer data, including the Orbitra Vault production environment, internal tools and third-party services. Violations may result in disciplinary action up to and including termination.

2. Certifications

Orbitra holds a SOC 2 Type II report, renewed annually, and has been ISO/IEC 27001 certified since November 2025. Customers can request the latest SOC 2 report under NDA through their account manager.

3. Encryption

All customer data is encrypted at rest using AES-256. Data in transit is protected with TLS 1.2 or higher; TLS 1.3 is preferred and enabled by default on all public endpoints. Encryption keys are managed in a hardware-backed key management service and are rotated every 90 days. Enterprise customers may bring their own customer-managed keys (CMK); if a customer revokes their key, their data becomes unreadable within 15 minutes.

4. Data residency

Customers choose a data region when their workspace is created. Data does not leave the chosen region except for encrypted disaster-recovery backups, which stay within the same geography.

Region	Location	Status
EU	Frankfurt, Germany	Generally available
US	Virginia, United States	Generally available
Middle East	Bahrain	Planned for Q3 2026

5. Access control

- Multi-factor authentication (MFA) is mandatory for every employee account, with hardware security keys required for engineers with production access.
- Employee passwords must be at least 14 characters long and must not be reused across systems.
- Access follows the principle of least privilege and is reviewed every quarter by each team's manager.
- Production access is granted just-in-time for a maximum of 4 hours, must be approved by the on-call lead, and every session is recorded.
- Accounts of departing employees are disabled within 1 hour of their last working day.

6. Data retention and deletion

Data type	Retention period
Files in Trash	30 days, then permanently deleted
Audit logs (Business and Enterprise)	400 days
Application and access logs	90 days
Backups	35 days rolling
Data of cancelled workspaces	Deleted 60 days after cancellation

When a file is permanently deleted, it is purged from all backups within 35 days. Customers can request a data export at any time before workspace deletion.

7. Backups and disaster recovery

Production databases and file storage are backed up every 6 hours. This gives a Recovery Point Objective (RPO) of 6 hours and a Recovery Time Objective (RTO) of 4 hours. Disaster-recovery drills are performed twice a year and results are reported to the leadership team.

8. Incident response

Severity	Description	Response time
SEV1	Complete outage or confirmed data breach	15 minutes, 24/7
SEV2	Major feature unavailable for many customers	30 minutes, 24/7
SEV3	Partial degradation with a workaround	4 business hours
SEV4	Minor issue, no customer impact	Next business day

Affected customers and the relevant supervisory authorities are notified of a confirmed personal-data breach within 72 hours of Orbitra becoming aware of it. A written post-incident review is published internally within 5 business days of every SEV1 and SEV2 incident.

9. Security testing

An independent third party performs a penetration test at least once a year and after every major release. Orbitra also runs a public bug bounty programme; rewards range from USD 200 for low-severity findings up to USD 10,000 for critical vulnerabilities.

10. Use of AI tools

Employees may only use AI tools approved by the Security team. Customer content must never be pasted into consumer AI chatbots. Approved AI features inside Orbitra products must not use customer data to train models, and all such features must pass a security and privacy review before launch.

11. Third-party vendors

Every vendor that will process customer data must complete a security questionnaire and sign a data processing agreement before onboarding. High-risk vendors are re-assessed every year.